LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

# Vikunja CVE-2026-123493 Bot Token Authentication Bypass Daily Priority

CVE / Vulnerability Threat Intelligence Report

| | |
|---|---|
| **Classification** | TLP:CLEAR |
| **Published** | 2026-11-10 |
| **Version** | 1.0 |
| **Author** | Lost Boys Cyber |
| **Report Type** | CVE / Vulnerability Threat Intelligence Report |

TLP:CLEAR | Lost Boys Cyber | Vikunja CVE-2026-123493 Bot Token Authentication Bypass Daily Priority - CVE / Vulnerability Threat Intelligence Report

Published: 2026-11-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

# Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Mitigation and Workarounds
8. Detection Engineering
    8.1. Hunt Query
9. Threat Hunting
    9.1. Hunt Hypothesis
10. MITRE ATT&CK Mapping
11. Validation / Lab Testing
12. Recommended Actions Summary
13. References

# Vikunja CVE-2026-123493 Bot Token Authentication Bypass Daily Priority

## 1. Executive Summary

CVE-2026-123493 is a newly published Vikunja authorization defect affecting versions 2.4.0 through versions before 2.7.1. Public advisory material states that disabled or locked users can retain access through API tokens owned by their bot users because token validation checks the bot-user status rather than the owning user's status. The result is a revocation failure: a previously issued token may continue to read and modify shared projects through the HTTP API, CalDAV, MCP, and feeds.

This is not a public-internet unauthenticated compromise claim. The published CVSS v3.1 score is 5.4 and the stated precondition is possession of a pre-minted bot token. It is nevertheless a priority for organizations using Vikunja for operational workflows, because account disablement is often relied upon during offboarding and incident response. No reviewed source asserted active exploitation; treat this as a patch-and-revocation validation requirement rather than an incident attribution finding.

## 2. Vulnerability Metadata

| Field | Value |
|---|---|
| CVE | CVE-2026-123493 |
| Product / component | Vikunja bot-user API-token validation |
| Affected versions | 2.4.0 through versions before 2.7.1 |
| Fixed version | 2.7.1 or later, per upstream advisory wording |
| CVSS | 5.4 (CVSS v3.1, network, low complexity, low privileges, no user interaction) |
| Confidentiality / integrity | Low / low; availability none in published scoring |
| Exploitation status | No active exploitation statement located in reviewed sources |

## 3. Source Review & Confidence

| Source | Contribution | Confidence |
|---|---|---|
| NVD CVE API record | CVE record, score, affected range, and source links | High |
| GitHub Security Advisory GHSA-5fc2-w2j4-6r8w | Upstream-associated advisory and remediation version | High |
| VulnCheck advisory | Technical explanation of bot-token ownership behavior | Medium |
| Rapid7 CVE database | Independent CVE reproduction and publication timing | Medium |

The CVE was published on 2026-11-08. The vulnerable-range and token-validation explanation are consistent across the reviewed records. This report does not independently test Vikunja or verify a local deployment configuration.

## 4. Vulnerability Details

The defect is relevant where a user has a bot user and a token was issued before the owner was disabled or locked. The advisory describes a validation path that evaluates the bot's own status but not the owning account's status. An actor holding such a token can retain project access even though the normal user account has been disabled.

The practical risk is strongest where API, CalDAV, MCP, or feed endpoints are exposed to third-party integrations; where personal access tokens are not centrally inventoried; or where offboarding depends only on account disablement. The public record does not establish arbitrary administrator access, code execution, or access without a pre-existing token.

## 5. Attack Scenarios

| Scenario | Preconditions | Defender focus |
|---|---|---|
| Departed user retains API access | Bot token exists before account lock/disable | Upgrade and revoke/rotate bot tokens |
| Compromised token survives containment | Token was stolen before user disablement | Search token use after containment timestamp |
| Integration uses an orphaned bot identity | Ownership and token lifecycle are not documented | Reassign, reissue, and scope integration tokens |

## 6. Affected Products and Exposure

| Exposure pattern | Why it matters | Priority |
|---|---|---|
| Vikunja 2.4.0 to pre-2.7.1 with bot users | Account lock may not revoke associated bot tokens | High |
| Internet-exposed API or CalDAV | Retained token can be used remotely | High |
| Internal-only deployment with SSO | Reduced reachability, but revocation gap remains | Medium |
| 2.7.1+ with token inventory validated | Residual risk depends on historical token use | Medium |

## 7. Mitigation and Workarounds

1. Inventory Vikunja versions, bot users, service accounts, and API tokens; identify installations below 2.7.1.
2. Upgrade using the upstream-supported release path and validate normal login, bot, API, CalDAV, MCP, and feed integrations after change control.
3. Revoke and reissue bot-user tokens associated with users who are disabled, locked, departed, or under investigation.
4. Review access-control and audit logs for token activity after the owning account's disablement timestamp.
5. Reduce token lifetime and scope where the platform and integration design support it; record an accountable owner for every automation identity.
6. Preserve access logs before upgrades or token cleanup if an offboarding or compromise investigation is open.

## 8. Detection Engineering

| Signal | Telemetry source | Analytic goal |
|---|---|---|

| | | |
|---|---|---|
| API request authenticated by bot token after owner disabled | Vikunja audit/application logs; identity records | Detect failed revocation |
| Token used from a new network after account lock | Reverse proxy and application logs | Identify retained-token abuse |
| Bot-user administration or token creation near offboarding | Application audit logs | Identify lifecycle-control gaps |

### 8.1. Hunt Query

```
AppServiceHTTPLogs
| where TimeGenerated > ago(30d)
| where CsUriStem has_any ('/api/', '/dav/', '/feed')
| where ScStatus between (200 .. 299)
| project TimeGenerated, Computer, ClientIP=CIp, Method=CsMethod, Uri=CsUriStem, UserAgent=UserAgent
| order by TimeGenerated desc
```

Map successful API activity to the platform's bot-token and owner records. Query syntax and field names must be adapted to the deployed reverse-proxy or SIEM parser.

## 9. Threat Hunting

### 9.1. Hunt Hypothesis

If the revocation gap has been used, a token associated with a disabled owner will continue to make successful API, CalDAV, MCP, or feed requests after the owner's disablement event.

```
index=vikunja (endpoint="/api/*" OR endpoint="/dav/*" OR endpoint="/feed*") status=200
| lookup disabled_vikunja_owners.csv token_owner OUTPUT owner_status disabled_at
| where owner_status="disabled" AND _time > strptime(disabled_at, "%Y-%m-%dT%H:%M:%S")
| stats values(endpoint) as endpoints values(src_ip) as source_ips min(_time) as first_seen max(_time)
as last_seen by token_id, token_owner
```

Validate matches against authoritative platform data before concluding that a token is malicious; integrations can have documented ownership changes that need normalization.

## 10. MITRE ATT&CK Mapping

| Technique | Name | Rationale |
|---|---|---|
| T1078 | Valid Accounts | A retained bot token can provide account-context access |
| T1528 | Steal Application Access Token | Stolen pre-existing tokens are a relevant precondition to investigate |
| T1098 | Account Manipulation | Review bot-user and token lifecycle changes for persistence-like access |

## 11. Validation / Lab Testing

No bypass was attempted. Validate upgrades and revocation semantics only in an authorized environment: create a test owner and bot token, disable the owner, confirm token rejection after the fixed release, and document the expected log events. Do not test against production data without change approval.

## 12. Recommended Actions Summary

| Priority | Owner | Action |
|---|---|---|
| High | Application owner | Upgrade affected Vikunja instances to |

| | | |
|---|---|---|
| | | 2.7.1+ |
| High | IAM / platform operations | Revoke and reissue tokens tied to disabled or departed owners |
| High | SOC | Hunt successful token activity after disablement timestamps |
| Medium | Governance | Establish bot/service-account ownership and periodic token review |

## 13. References


- NVD, CVE-2026-123493: https://nvd.nist.gov/vuln/detail/CVE-2026-123493
- GitHub Security Advisory, GHSA-5fc2-w2j4-6r8w: https://github.com/go-vikunja/vikunja/security/advisories/GHSA-5fc2-w2j4-6r8w
- VulnCheck, Vikunja authentication bypass via bot API tokens: https://www.vulncheck.com/advisories/vikunja-from-2.4.0-before-2.7.1-authentication-bypass-via-bot-api-tokens
- Rapid7, CVE-2026-123493: https://www.rapid7.com/db/vulnerabilities/cve-2026-123493/